

Access control investigation and unauthorized account reviewed

1. Scenario

Investigated a suspicious payroll modification incident at a growing organization. An unauthorized bank account was added to the payroll system, prompting an analysis of access logs, user authorizations, and account management practices.

2. Objective

Identify weakness in access control processes, determine how an inactive contractor account was able to access sensitive payroll systems, and recommend security improvements to prevent future incidents.

3. Activities performed

- reviewed authentication and authorization records.
- Analyzed access logs associated with payroll system activity.
- Identified a privileged account linked to a former contractor.
- Examined user account lifecycle management controls.
- Evaluated authorization levels and role assignments.
- Assessed risks associated with inactive privileged accounts.
- Developed remediation recommendations based on access control best practices.

4. Key findings

- a contractor account retained administrator privileges after contract termination.
- The account was still active despite the contractor leaving the organization in 2019.
- The privileged account was used to access payroll resources in 2023.
- Excessive permissions and poor account deprovisioning created an insider threat risk.

5. Recommendations

- automatically disable contractor accounts after contract expiration.
- Implement periodic access reviews.
- Apply least privilege principles to administrative accounts.
- Restrict access to payroll systems based on business requirements.
- Enable multi-factor authentication (MFA)
- Improve identity and access management (IAM) procedures.

6. Framework and concepts

- access control
- Authentication
- Authorization
- Identity and access management (IAM)
- Least Privileged
- Account Lifecycle Management
- Multi-factor authentication (MFA)

7. Skills demonstrated

- log analysis
- User access review
- Incident investigation
- Authorization assessment
- Risk identification

- Security recommendations
- Identity and access management